

L2 - 10.1. Preparation

Task 1 - Introduction

The Preparation phase is the foundation of every effective incident response capability. Before an organization can detect, contain, or recover from a security incident, it must have the right people, processes, and technology in place. Without preparation, even the most skilled analyst will struggle to respond effectively when an incident occurs.

Task 2 - What Is Incident Response

Incident response is the structured approach an organization takes to prepare for, detect, contain, and recover from security incidents while minimizing damage and reducing recovery time.

Term	Definition
Event	Any observable occurrence within a system or network. Events happen constantly, and the vast majority are completely normal. A user logging in, an email being delivered, and a file being opened are all events. Notable events are transitioned into alerts thanks to detection rules and security tools .
Alert	A notification generated by a security tool indicating that something may require attention. Not every alert represents a real threat. Alerts can be escalated to incidents after a thorough alert triage .
Incident	A confirmed violation of security policies or practices that has a negative impact on the organization. An incident is declared when evidence confirms that a threat is real and action is required.

What Triggers an Incident Response: An IR process can be triggered by many sources, not just automated alerts from a SIEM. Common triggers include:

- A security alert escalated by a SOC analyst
- A user reporting suspicious email or unexpected account behavior
- An automated detection from an EDR or SIEM tool

- A third party, such as a threat intelligence provider or law enforcement, notifying the organization
- A threat intelligence feed flagging infrastructure associated with the organization

How Nexus Financial Handles This: Nexus Financial ensures robust incident handling through a dedicated security team where SOC engineers build detections, analysts triage threats, and a compliance team manages external reports.

Answer the questions below

| What is declared after a threat is confirmed?

Incident

| What must be completed on an alert before the IR process can formally begin?

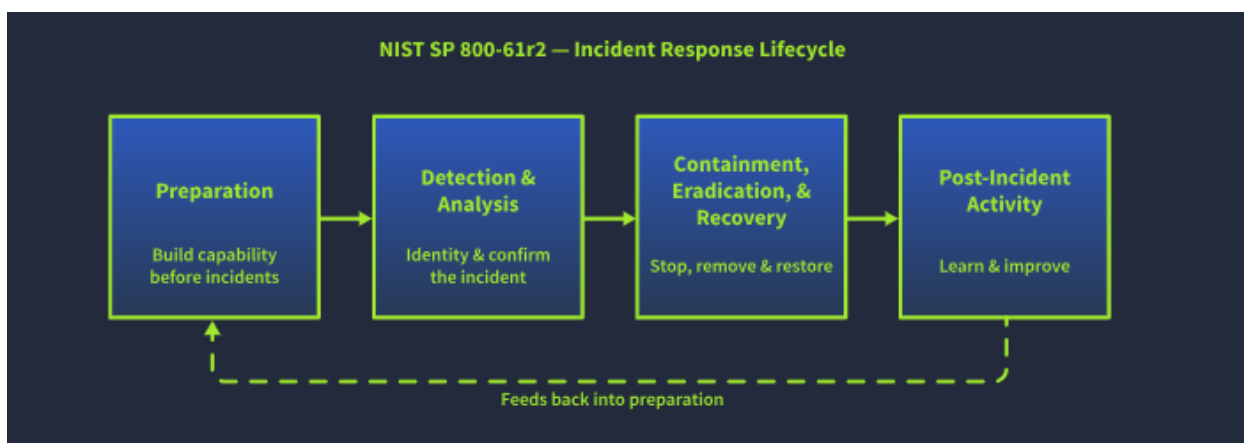
Alert Triage

Task 3 - IR Frameworks

A framework provides the IR team with a proven, repeatable process to follow regardless of the incident type or severity. It removes the need to make structural decisions under pressure and ensures that nothing important is overlooked. Frameworks also provide a common language across teams, making it easier to coordinate internally and communicate with external parties such as legal counsel or law enforcement.

Phase	Description
Preparation	Covers all the work done before an incident occurs. This includes building the IR team, defining policies and procedures, deploying detection tools, and ensuring adequate logging and visibility across the environment.
Detection and Analysis	Covers the identification of potential incidents, the triage of alerts, and the analysis required to confirm that an incident has occurred and understand its nature and scope.

Phase	Description
Containment, Eradication, and Recovery	Covers the active response to a confirmed incident. Containment limits further damage, eradication removes the threat from the environment, and recovery restores normal business operations.
Post-Incident Activity	Covers the lessons learned process. This includes reviewing what happened, documenting the findings, and using what was learned to improve the organization's defenses and response procedures.



Nexus Financial bases its incident response policy on NIST SP 800-61, but critical gaps in foundational preparation controls expose vulnerabilities when executing the plan in practice.

Answer the questions below

How many phases does the NIST SP 800-61 IR lifecycle have?

4

According to NIST SP 800-61, what phase follows Containment, Eradication, and Recovery?

Post-Incident Activity

Task 4 - People, Processes, and Technology

The group responsible for managing security incidents is commonly referred to as a Cyber Security Incident Response Team, or **CSIRT**. You may also encounter this team referred to as a Computer Emergency Response Team (**CERT**), a Security Incident Response Team (**SIRT**), or simply an Incident Response Team (**IRT**). The name varies between organizations, but the function is the same. In smaller organizations, there may not be a dedicated CSIRT. In these cases, SOC analysts temporarily take on the incident response role when an incident is declared. This is a common practice in organizations that do not have a high enough incident volume to justify a permanently staffed IR function.

Processes define how the IR team operates. Key documents include:

Document / Tool	Purpose
Incident Response Plan	Defines the overall approach the organization takes when managing incidents. Covers roles and responsibilities, escalation paths, communication channels, and how the effectiveness of the response is measured.
Communication Plan	Defines who within the CSIRT is the point of contact for different incident types, when to notify law enforcement or third parties, and how to manage communications during a high-profile breach.
Playbooks	Provide step-by-step procedures for specific incident types such as phishing, ransomware, or data breach. Give responders a clear path to follow without having to make every decision under pressure.
Chain of Custody Documents	Track the handling of evidence from collection through analysis to storage. Essential for any incident that may result in legal proceedings, and must record who handled evidence, when, and why.
Ticketing Systems	Provide a central record of all investigation activity. Every action taken, every finding made, and every decision reached should be logged to ensure the investigation has a complete, auditable trail.
Asset Inventory	A complete and up-to-date list of all hardware and software within the organization. Without knowing what assets exist, it is impossible to know what has been compromised.

Some of the core technologies that support incident response include:

Tool	Purpose
Security Information and Event Management (SIEM)	The central hub of most IR operations. Collects logs from across the environment, correlates events, and generates alerts when suspicious activity is detected. In this module, the SIEM is where the investigation takes place across the upcoming rooms.
Endpoint Detection and Response (EDR)	Monitors activity on individual devices and can detect, alert on, and in some cases automatically respond to malicious behavior at the endpoint level.
Intrusion Detection and Prevention Systems (IDPS)	Monitors network traffic for known attack patterns and anomalous behavior. Detection systems alert on suspicious traffic, while prevention systems can actively block it.
Data Loss Prevention (DLP)	Monitors and controls the movement of sensitive data within and outside the organization. Can detect and block unauthorized data transfers before exfiltration occurs.
Threat Intelligence Platforms	Aggregate and contextualize information about known threats, attacker infrastructure, and malicious indicators. Helps IR teams understand who they are dealing with and anticipate attacker behavior.
Forensic Tools	Support the collection and analysis of evidence during an investigation. Includes disk and memory imaging software, packet-capture tools, and log-analysis utilities.

Where Nexus Financial Stands: Nexus Financial maintains an operational CSIRT with dual-hatted Security Analysts, an IR policy, communication plans, and SIEM detection, though its real-world effectiveness remains to be tested.

Answer the questions below

What document tracks the handling of evidence from collection through to storage?

Chain of Custody

Task 5 - Visibility, Logging, and Detection

Types of Log Entries

- **Event log:** Records observable occurrences within a system, such as login attempts, application activity, and network connections.
- **Audit log:** Records a sequential history of actions taken within a system. Captures who performed an action, what the action was, and how the system responded. Split into success and failure categories; essential for investigations involving account activity and data access.
- **Error log:** Records system failures such as a crashed service or an application error.
- **Debug log:** Records detailed diagnostic information used during testing and troubleshooting.

Types of Log Sources

- **Network logs:** Come from routers, switches, and firewalls and record traffic flows and connection attempts.
- **Host perimeter logs:** Come from proxies, VPN servers, and boundary firewalls and capture what traffic enters and leaves the environment.
- **System logs:** Come from the operating systems on servers and workstations and include login events, process execution, and configuration changes.
- **Application logs:** Come from business applications, cloud platforms, and databases. In cloud-based environments such as Microsoft 365, logs from Exchange Online, SharePoint, and Entra ID are among the most valuable sources for investigating identity-based attacks.

Answer the questions below

What type of log records who performed an action, what the action was, and how the system responded?

Audit Log

What technology provides a centralized platform for collecting and analyzing logs across an organization's infrastructure?

SIEM

What term describes the situation where logs are collected but no alerting rules exist to flag suspicious activity?

Detection Gap

Task 6 - Practical

Nexus Financial uses **Microsoft 365** for email, file storage, and collaboration, and **Entra ID** as its identity and access management platform. All employee accounts are managed through Entra ID, and all email, SharePoint, and Teams activity runs through Microsoft 365.

The documents in the folder are:

- Asset_Inventory
- IR_Policy
- Communication_Plan
- Pentest_Report_2025
- Historic_Incidents

Once you have reviewed the documents, check the local security policies on this workstation (Part of Nexus Financial's Asset Inventory). On the lab machine, open the run dialogue, type `secpol.msc`, and press Enter. This opens the Local Security Policy. Navigate to the **Policies** under **Security Settings**, then review them. Use the documents and the local security settings to answer the questions below.

Answer the questions below

According to the asset inventory, what is the IP address of the mail server?

10.10.10.2

HARDWARE ASSETS

ID	Type	Name	IP Address	OS	Owner
NXF-001	Domain Controller	DC-01	10.10.10.1	Windows Server 2022	David Soto
NXF-002	Mail Server	MAIL-01	10.10.10.2	Windows Server 2022	David Soto
NXF-003	SharePoint Server	SP-01	10.10.10.3	Windows Server 2022	David Soto
NXF-004	File Server	FS-01	10.10.10.4	Windows Server 2019	David Soto
NXF-005	Workstation	WS-01	10.10.10.10	Windows 11 Pro	James Willard
NXF-006	Workstation	WS-02	10.10.10.11	Windows 11 Pro	Sarah Kimani
NXF-007	Workstation	WS-03	10.10.10.12	Windows 11 Pro	David Soto
NXF-008	Workstation	WS-04	10.10.10.13	Windows 11 Pro	Marcus Webb
NXF-009	Laptop	LT-01	10.10.10.20	Windows 11 Pro	James Willard

According to the pentest report, what authentication control is flagged as missing on standard user accounts?

Multi-Factor Authentication

3. DETAILED FINDINGS

NXF-PT-001: Multi-Factor Authentication Not Enforced on Standard User Accounts
Severity : High
Affected Service: Entra ID -- All standard user accounts
Status : Open -- Not remediated as of March 2026

According to the pentest report, how many high-severity findings were identified?

2

FINDINGS SUMMARY

Critical : 0
High : 2
Medium : 3
Low : 1

According to the historic incidents log, what type of attack was recorded in NXF-INC-001?

Phishing Campaign

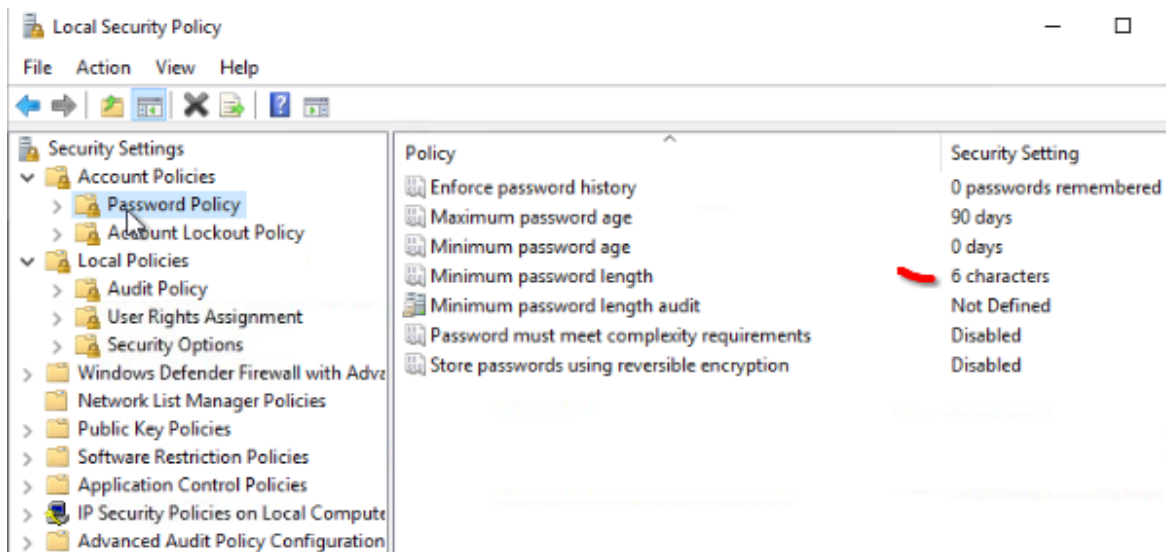
INCIDENT SUMMARY

ID Date Type Severity Status

NXF-INC-001	July 2025	Phishing Campaign	Medium	Closed
NXF-INC-002	September 2025	Malware Detection	Low	Closed
NXF-INC-003	December 2025	Unauthorised Access Attempt	Low	Closed

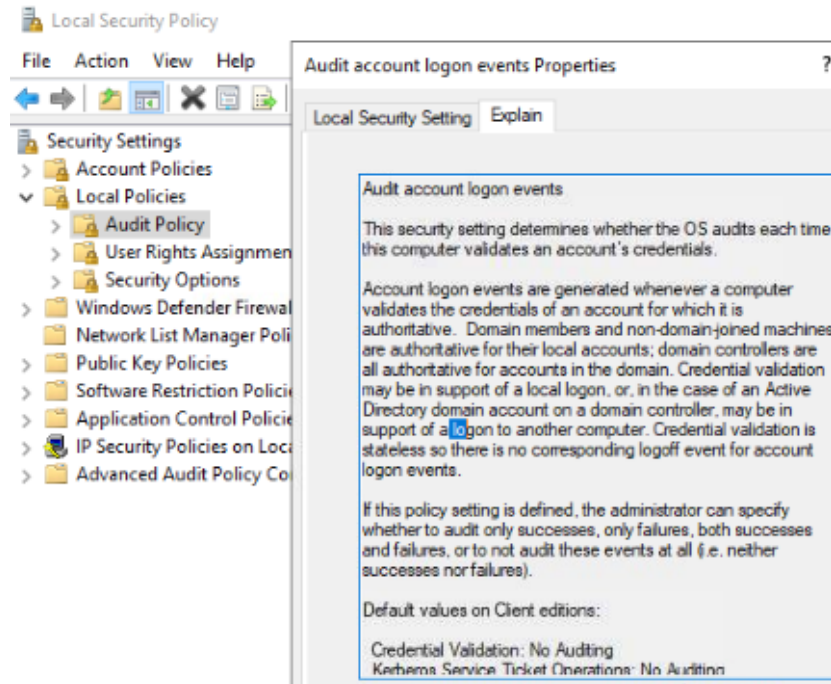
What is the minimum password length configured on this workstation?

6



What is the audit setting configured for Audit account logon events?

No auditing



Task 7 - Conclusion

The Preparation phase happens before the incident. It rarely gets credit when things go well, and it is easy to deprioritize when there are more pressing operational demands. But the Nexus Financial documents you reviewed in this room tell a familiar story: an organization that had some foundations in place but left critical gaps unaddressed.

Missing MFA on standard user accounts. No email authentication controls on the domain. A previous phishing incident closed without fixing the root cause. These are not unusual findings. They appear in organizations of every size and industry. What makes them significant is the chain of consequences they create. One unaddressed finding in a pentest report becomes the initial access vector in the next incident. One previous incident closed without a root cause fix leaves the same door open for the next attacker.